



Devoir Surveillé – BTS SIO 1ere année (B3)

Sécurité des Applications Web : Les bases de l'OWASP

Durée totale : 1 heure

Partie 1 – Connaissances de cours

Partie 2 – Analyse de cas simples

La clarté des explications et le soin apporté à la copie seront pris en compte dans l'évaluation.

Partie 1 – Connaissances de base (10 points)

1.1 Association de concepts (4 points)

Associer chaque faille de l'OWASP à la situation qui lui correspond (écrire simplement les paires sur votre copie, par exemple : 1-B).

Les failles :

1. **A01 : Broken Access Control** (Contrôle d'accès défaillant)
2. **A03 : Injection**
3. **A05 : Security Misconfiguration** (Mauvaise configuration)
4. **A07 : Identification and Authentication Failures** (Défaut d'authentification)

Les situations :

- **A.** Le serveur affiche un message d'erreur technique très détaillé incluant des numéros de version du système.
- **B.** L'application permet à un utilisateur de se connecter en essayant 10 000 mots de passe à la suite sans le bloquer.
- **C.** Un pirate insère du code SQL dans un formulaire de recherche pour tromper la base de données.
- **D.** Un simple client arrive à accéder à la page `admin.php` car le serveur ne vérifie pas son statut.

1.2 Cryptographie et Authentification (3 points)

1. Expliquer brièvement pourquoi il ne faut **jamais** stocker un mot de passe en texte clair dans une base de données (Faille A02). (1 point)
2. L'algorithme **RSA** est très utilisé pour sécuriser les échanges (chiffrement asymétrique). Combien de clés utilise-t-il par utilisateur et quel est le rôle de chacune ? Comment fonctionne ce chiffrement ? (1 point)
3. Qu'est-ce que le **MFA** (Authentification Multi-Facteurs) et à quoi sert-il pour sécuriser les comptes utilisateurs ? Donner un exemple concret. (1 point)

1.3 Vulnérabilités et Mises à jour (3 points)

1. Que signifie le terme **CVE** dans le domaine de la cybersécurité et à quoi cela sert-il ? (1 point)
2. Vous installez un logiciel tiers sur votre serveur web. Pourquoi est-il critique d'appliquer très régulièrement les mises à jour de sécurité (patches) publiées par l'éditeur (Faille A06 : Composants vulnérables et obsolètes) ? (2 points)

Partie 2 – Analyse de cas simples (10 points)

Cas Pratique n°1 : L'URL curieuse (5 points)

Contexte : Alice se connecte à son espace client sur une boutique en ligne pour télécharger sa dernière facture. Elle remarque que l'URL dans son navigateur est la suivante :

```
https://boutique.fr/mes-factures.php?id_facture=105
```

Par curiosité, elle modifie le nombre 105 par 106 et appuie sur Entrée. Le site lui affiche alors la facture de Bob, un autre client, avec son adresse et ses achats.

Questions :

1. Quel est le nom précis de cette vulnérabilité (qui appartient à la catégorie A01 de l'OWASP) ? (1 point)
2. Le problème vient-il du navigateur d'Alice ou du code situé sur le serveur de la boutique ? Justifiez. (1 point)
3. **Logique de correction :** Expliquez avec des mots simples comment le développeur doit modifier la page `mes-factures.php` pour empêcher cette attaque. Que doit vérifier le serveur avant d'afficher le fichier demandé ? (3 points)

Cas Pratique n°2 : Le formulaire de connexion (5 points)

Contexte :

Un développeur débutant a codé le formulaire de connexion de son site web. Voici la requête qui est envoyée à la base de données :

```
SELECT * FROM utilisateurs WHERE email = '[EMAIL_SAISI]' AND mot_de_passe = '[MDP_SAISI]'
```

Un attaquant décide de saisir la phrase suivante dans le champ email : `' OR '1'='1`

Questions :

1. À quelle catégorie du Top 10 OWASP cette attaque appartient-elle ? (1 point)
2. Expliquer pourquoi le texte `' OR '1'='1` permet à l'attaquant de se connecter au site, même s'il ne connaît pas le vrai mot de passe. Que comprend la base de données au moment de lire la requête ? (2 points)
3. Quelle est la technique de programmation incontournable (la "règle d'or") que le développeur doit utiliser côté serveur pour sécuriser définitivement ses requêtes SQL contre cette faille ? (2 points)